

Risk Treatment & Security Operations

IS 2204 - Information Systems Security

Dilanga Harshani

Content adapted from
Prof. Kasun De Zoysa & Mr. Kenneth Thilakarathna

University of Colombo School of Computing

August 10, 2026

Where You Are

- Introduction to Information Security and CIA Triad
- Symmetric and Asymmetric Cryptography
- Email and Document Security
- Transport Layer Security
- Payment Security and Blockchain
- Network Security Protocols
- Malicious Code and Defences
- Authentication Protocols
- Risk Identification and Assessment
- **Risk Treatment and Security Operations**

Today's Roadmap

- **Measuring Risk** : Turning identified risk into a comparable number
- **Treating Risk** : What an organisation actually does about it
- **Controls** : Classifying the countermeasures themselves
- **Security Operations** : Who carries all of this out, continuously

Qualitative vs Quantitative Risk Assessment

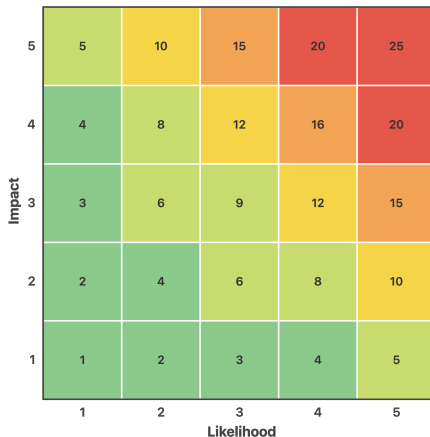
- **Qualitative** : Descriptive categories (High / Medium / Low) which are fast, accessible, but subjective
- **Quantitative** : Actual numbers (cost, probability) which are precise, but requires data that is often hard to obtain accurately
- Most organisations blend both, qualitative for a fast pass across many risks, quantitative for the highest-priority few

Calculating Risk Score

$$\text{Risk Score} = \text{Likelihood} \times \text{Impact}$$

- The practical, operational version of Risk = Threat $\times$ Vulnerability $\times$ Asset Value
- Likelihood folds threat and vulnerability together
- Impact captures asset value in terms of actual consequence

The Risk Matrix



- Instantly communicates priority, even to a non-tech audience

Single Loss Expectancy (SLE)

$$\text{SLE} = \text{Asset Value} \times \text{Exposure Factor}$$

- How much would a single occurrence of this risk actually cost?
- Exposure Factor is the percentage of the asset's value lost in one incident, rarely 100%

Annualized Rate of Occurrence and Loss Expectancy

$$ALE = SLE \times ARO$$

- Annualized Rate of Occurrence (**ARO**) : How many times per year this is expected to occur (can be less than 1)
- Annualized Loss Expectancy (**ALE**) : The expected annual cost of the risk, blending severity and frequency into one figure

Worked Example : Registration System Downtime

Quantity	Value
Asset value (registration revenue + reputational cost of a term's registration)	\$200,000
Exposure Factor (server crash during add/drop week)	25%
SLE	\$50,000
ARO (occurs roughly once every 2 years)	0.5
ALE	\$25,000 / year

A load-balancing upgrade costing less than \$25,000/year to prevent this risk is a justified investment.

Limitations of Quantitative Risk

- Input numbers are often estimates, not hard facts
- Rare, catastrophic events are poorly captured by annualised averaging
- Intangible impacts (reputation, trust) resist clean quantification
- Precise looking numbers can create false confidence in what are ultimately estimates

Risk Treatment Strategies

Strategy	Description	Trade-off
Avoid	Eliminate the activity that creates the risk	Full elimination, but often at the cost of a capability
Mitigate	Reduce likelihood or impact via controls	Lowers exposure, but residual risk remains
Transfer	Shift financial consequence to a third party	Predictable cost, but does not reduce likelihood
Accept	Consciously do nothing further	No added cost, only valid for genuinely low risk

Avoid the Risk

- Eliminates the risk entirely by removing its source or changing the underlying plan
 - A university decides not to store student medical records online, to avoid the risk of a breach entirely
- Best when a risk is too severe to control cost-effectively
- The risk is gone, no ongoing management cost
- Usually means giving up a real capability or business, rarely appropriate

Mitigate the Risk

- Reduces the likelihood or impact of a risk, without eliminating the underlying activity
 - Encrypting student data to limit the damage if a breach still occurs
- Best when the underlying activity is necessary and cannot reasonably be avoided
- Risk is reduced while the underlying capability is retained
- Never brings risk to zero, and carries an ongoing cost to maintain

Transfer the Risk

- Shifts the financial consequence of a risk to a third party, usually via contract or insurance
 - Purchasing insurance that covers the costs of a ransomware attack
- Best when an incident's cost is severe but insurable, and further reducing the risk itself has diminishing returns
- Converts an unpredictable, potentially catastrophic loss into a fixed, budgeted cost
- Doesn't reduce likelihood, and policies often carry exclusions or required controls to qualify

Accept the Risk

- Consciously does nothing further beyond monitoring, when the risk is low or the cost of control is not justified
 - A university accepts the small risk of an older, non-critical system, due to budget constraints
- Avoids unnecessary spending on a low-priority risk
- Only valid when consciously chosen and documented. Accepting a high-impact risk with no plan is negligence, not a strategy

Controls : Classified by Implementation

- **Physical** : Measures that controls the physical environment (locks, fences, guards)
- **Administrative** : Implemented by rule, not by mechanism (policy, procedure, training)
- **Technical** : Software, hardware, or firmware that enforces a restriction directly (encryption, firewall)
- Every control implements one or more of confidentiality, integrity, or availability for a given asset

Controls : Classified by Function

- **Preventive** : Stops an incident before it happens (firewalls, authentication)
- **Detective** : Identifies that something has gone wrong (IDS, auditing, SIEM)
- **Corrective** : Respond or fix after an incident (backups, patches)
- A mature security programme deploys all three, prevention will eventually fail against something

Controls : Classified by Function

- **Deterrent** : Discourages an attempt through the threat of consequence (warning signage, visible cameras)
- **Directive** : Actively guides people toward compliant behaviour (policy, training, posted procedure)
- **Recovery** : Restores full normal operation after the incident is over (backups, disaster recovery sites)
- **Compensating** : An alternative safeguard used when the ideal control is not feasible

Control Implementation & Functional Categories

Control	Implementation	Function
Firewall	Technical	Preventive
Background check	Administrative	Preventive
Security guard	Physical	Deterrent, Detective
Backup system	Technical	Recovery
Incident response policy	Administrative	Corrective

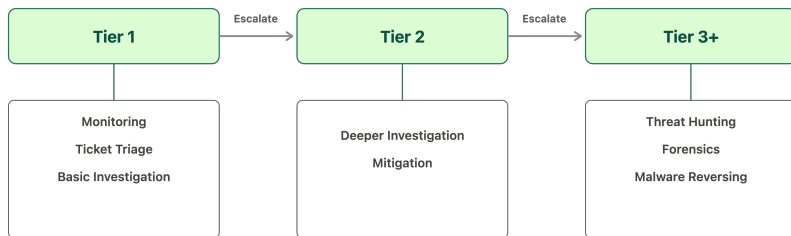
From Controls to Operations

- A control is only a mechanism, someone has to run it, watch it, and act on what it reports, continuously
- This is the organisational layer that turns risk treatment from a plan into an ongoing practice

Security Operations Center (SOC)

- Unifies and coordinates an organisation's threat detection, response, and prevention capabilities
- Key functions :
 - Continuous monitoring
 - Incident detection and response
 - Threat intelligence
 - Forensics
 - Compliance reporting

Security Operations Center Tiers

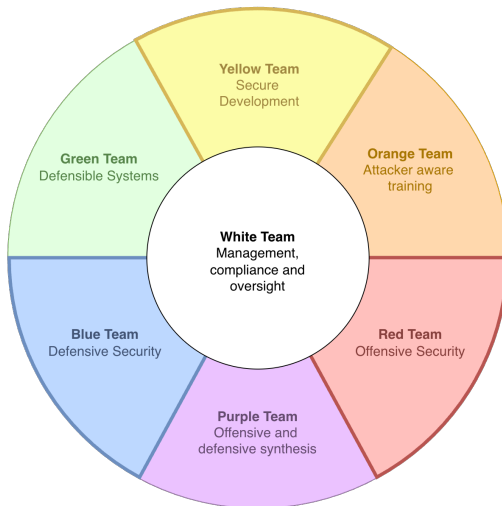


- **Tier 1** : Monitoring, opens tickets, basic investigation
- **Tier 2** : Deeper investigation, mitigation
- **Tier 3+** : Threat hunting, forensics, malware reversing
- Goal is to minimise how many incidents reach the higher, costlier tiers

The Colour-Coded Team Model

- Specialised teams that simulate attacks, defend systems, and improve security posture
 - Core teams : Red, Blue, Purple
 - Extended teams : Yellow, Green, Orange, White
- Not a formal standard but a widely adopted industry framework (originating from April C. Wright's "Orange Is the New Purple", Black Hat USA, 2017)
- Organisations adapt the colours to their own structure, what follows is one common version, not the only one

Overview of Security Teams



Red Team

- The offensive side, also known as “the Breakers”
- Runs vulnerability assessment as an ongoing organisational function, not a one-off audit
- Key responsibilities
 - Penetration testing
 - Social engineering
 - Full adversary simulation
- Tests whether preventive controls genuinely hold up under real pressure

Blue Team

- The defensive counterpart, also known as “the Defenders”
- Executes detective and corrective controls on a daily basis
- Key responsibilities
 - Incident response
 - Vulnerability management
 - Log analysis

Purple Team

- Blends Red and Blue capability into one coordinated function, not a separate skill set
- Ensures the two actually learn from each other, rather than operating in isolation
- Turns Red Team's discovered gaps and Blue Team's detection findings into an actual, concrete mitigation decision
- “We found a problem” becomes “here's the fix we're actually deploying”

Yellow Team

- Security embedded directly into software development itself, also known as “the Builders”
- Applies threat modeling at the point code is actually being written
- Key responsibilities
 - Secure coding
 - Cloud hardening
 - Design-phase threat modelling

Green Team

- Bridges Blue and Yellow, makes systems defensible, not just securely built
- Ensures Blue Team inherits systems they can actually see into, not just systems built carefully
- Key responsibilities
 - Adding logging and detection hooks during development
 - Embedding telemetry Blue Team can monitor
 - Closing the gap between what gets built and what can be defended

Orange Team

- Bridges Red and Yellow, trains developers to think like attackers
- Turns Red Team's findings into staff training rather than a report that sits unread
- Key responsibilities
 - Training developers on attack methods
 - Phishing Simulations
 - Tabletop Exercises
 - Behavioral Analysis

White Team

- Neutral oversight during Red vs Blue exercises, also known as “the Game Masters”
- Sets the rules of engagement and organises the other teams, without participating directly
- Key responsibilities
 - Scoping and rules of engagement
 - Monitoring for safety and fairness
 - Adjudicating disputed outcomes

How All Teams Work Together

- Threat intelligence informs both Red and Blue Team activity
- Purple Team synthesises their findings and routes outcomes onward
- Yellow, Green, and Orange Teams each turn those outcomes into a lasting improvement
- White Team ensures the Red-Blue exercises generating all of this stay fair and realistic in the first place
- SOC and the security teams are not a one-time project, they are the staffed, ongoing version of the risk management cycle itself

Compliance and Regulation

- Controls are chosen for risk reasons, compliance is often the reason they become mandatory
- Security standards protect the confidentiality, integrity, and availability of any asset (ISO/IEC 27001, SOC 2, PCI DSS)
- Privacy regulation grants individuals legal rights over their own personal data specifically (GDPR, CCPA, PDPA)
- Overlapping in practice, but legally and organisationally distinct obligations

Professional Certifications in Information Security

- No prior experience required
 - Certified in Cybersecurity CC (ISC2) : Foundational
 - CompTIA Security+ : Widely required entry-level credential
- Requires several years of professional experience
 - CISSP (ISC2) : Broad, management and technical, the field's best-known credential
 - CISM (ISACA) : Security management and governance
 - CISA (ISACA) : IT audit and compliance
- Specialised, hands-on paths
 - CEH (EC-Council) : Offensive security, ethical hacking
 - OSCP (OffSec) : Rigorous, practical penetration testing
 - CCSP (ISC2) : Cloud security architecture

Summary

- **Measuring risk** : Qualitative for speed, quantitative (SLE/ARO/ALE) for precision on the highest priorities
- **Treating risk** : Avoid, mitigate, transfer, or accept, each a genuine trade-off, not a default choice
- **Controls** : Classified by category (administrative, technical, physical) and by function at once
- **Compliance** : Turns some of these controls from optional to mandatory
- **Security operations** : The SOC and seven colour-coded teams are how all of the above actually gets carried out, continuously

Discussion